

Guidelines

On Internal Controls for Benchmark Administrators, Credit Rating Agencies and Market Transparency Infrastructures

Table of Contents

1	Scope	3
2	Legislative references, abbreviations and definitions	4
2.1	Legislative references	4
2.2	Abbreviations	5
2.3	Definitions	5
3	Purpose.....	7
4	Compliance and reporting obligations.....	7
4.1	Status of the guidelines.....	7
4.2	Reporting requirements.....	7
5	Guidelines on internal controls	9
5.1	Internal Control Framework.....	9
5.2	Internal Control Functions	14

1 Scope

Who?

1. These Guidelines apply to:
 - (i) benchmark administrators authorised, registered or recognised with ESMA (together 'BMAs') in accordance with BMR;
 - (ii) credit rating agencies established in the Union and registered with ESMA (CRAs) in accordance with CRAR;
 - (iii) data reporting services providers (excluding Consolidated Tape Providers (CTPs)) established in the Union and authorised by ESMA (DRSPs) in accordance with MiFIR;
 - (iv) securitisation repositories established in the Union and registered with ESMA (SRs) in accordance with SecR;
 - (v) trade repositories established in the Union and registered with ESMA (TRs) in accordance with EMIR;
 - (vi) trade repositories established in the Union and registered with ESMA in accordance with SFTR (hereinafter together referred to as 'Supervised Entities').

What?

2. These Guidelines concern matters relating to the internal control structure and mechanisms necessary to ensure (i) a BMA's effective compliance with Articles 4 to 10 of BMR; (ii) a CRAs' effective compliance with Article 6(1),(2) and (4), Article 9 and Annex I, Section A, of CRAR; (iii) a DRSP's effective compliance with Articles 27f, 27g, 27i of MiFIR; and (iv) a TR's or SR's effective compliance with Articles 78 and 79 of EMIR.

When?

3. These Guidelines apply from 1 October 2026.
4. As of the date referred to in Paragraph 3, the Guidelines on Internal Control for CRAs (ESMA33-9-371) are repealed.

2 Legislative references, abbreviations and definitions

2.1 Legislative references

BMR	Regulation (EU) 2016/1011 of the European Parliament and of the Council of 8 June 2016 on indices used as benchmarks in financial instruments and financial contracts or to measure the performance of investment funds and amending Directives 2008/48/EC and 2014/17/EU and Regulation (EU) No 596/2014 ¹
CRAR	Regulation (EC) No 1060/2009 of the European Parliament and of the Council of 16 September 2009 on credit ratings agencies ²
DORA	Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 ³
EMIR	Regulation (EU) No 648/2012 of the European Parliament and of the Council of 4 July 2012 on OTC derivatives, central counterparties and trade repositories ⁴
MiFIR	Regulation (EU) No 600/2014 of the European Parliament and of the Council of 15 May 2014 on markets in financial instruments and amending Regulation (EU) No 648/2012 ⁵
SecR	Regulation (EU) 2017/2402 of the European Parliament and of the Council of 12 December 2017 laying down a general framework for securitisation and creating a specific framework for simple, transparent and standardised securitisation, and amending Directives 2009/65/EC, 2009/138/EC and 2011/61/EU and Regulations (EC) No 1060/2009 and (EU) No 648/2012 ⁶
SFTR	Regulation (EU) 2015/2365 of the European Parliament and of the Council of 25 November 2015 on transparency of securities financing transactions and of reuse and amending Regulation (EU) No 648/2012 ⁷

¹ OJ L 171, 29.6.2016, p. 1.

² OJ L 302, 17.11.2009, p. 1.

³ OJ L 333, 27.12.2022, p. 1.

⁴ OJ L 201, 27.7.2012, p.1.

⁵ OJ L 173, 12.6.2014, p.84.

⁶ OJ L 347, 28.12.2017, p. 35.

⁷ OJ L 337, 23.12.2015, p.1.

2.2 Abbreviations

AI	Artificial intelligence
APA	Approved Publication Arrangement
ARM	Approved Reporting Mechanism
BMA	Benchmark Administrator
CP	Consultation Paper
CRA	Credit Rating Agency
DORA	Digital Operational Resilience Act
DRSP	Data Reporting Services Provider
ESMA	European Securities and Markets Authority
EU	European Union
IC Framework	Internal Control Framework
IC Function	Internal Control Function
ICT	Information and Communication Technology
INED	Independent Non-Executive Director
MI	Management Information
RTS	Regulatory Technical Standards
SR	Securitisation Repository
TR	Trade Repository

2.3 Definitions

Executive Senior
Management

This refers to the most senior persons directing the supervised entity on a day-to-day basis. This is typically the Chief Executive Officer (CEO) or equivalent and his/her direct reports.

Management Body	The body or bodies which are appointed in accordance with national law, which are empowered to set the entity's strategy, objectives and overall direction, and which oversee and monitor management decision-making and include persons who effectively direct the business of the entity. This refers to the most senior governing bodies within an organisation. The term is defined in BMR, Article 3(1), point (20) and in MIFIR, Article 2(1), point (22). It covers the concepts of: ▪ 'administrative or supervisory board', of a CRA, being part of 'senior management', as defined in CRAR, Article 3(1), point n)] ▪ 'administrative or supervisory board, or both, in accordance with national company law', as defined in EMIR, Article 2(27)
Market Transparency Infrastructures	For the purpose of these Guidelines, this refers to: ▪ Data Reporting Services Providers, ▪ Securitisation Repositories and ▪ Trade Repositories
Relevant Regulations	For the purpose of these Guidelines, this refers to: ▪ BMR ▪ CRAR ▪ EMIR ▪ MiFIR ▪ SecR ▪ SFTR
Supervised entities	For the purpose of these Guidelines, this refers to the entities under ESMA's supervisory remit, namely: ▪ BMAs ▪ CRAs ▪ DRSPs (excluding consolidated tape providers) ▪ SRs ▪ TRs

3 Purpose

5. These Guidelines set out ESMA's expectations regarding the components and characteristics of an effective internal control framework and the functions of different internal controls within a supervised entity.

4 Compliance and reporting obligations

4.1 Status of the guidelines

6. This document contains Guidelines issued pursuant to Article 16 of the ESMA Regulation. In accordance with Article 16(3) of the ESMA Regulation, supervised entities must make every effort to comply with these Guidelines.

4.2 Reporting requirements

7. Financial market participants to which these Guidelines apply are not required to report whether they comply with these Guidelines. ESMA will assess the application of these Guidelines by the supervised entities through its ongoing supervision and monitoring of supervised entities' activities.
8. ESMA will apply proportionality in the application of these Guidelines. While all supervised entities are expected to demonstrate the components and characteristics of an effective internal control system outlined in these Guidelines, ESMA will calibrate its expectations under Section 4.2 according to the nature, scale, complexity and overall risk profile of a supervised entity and based how these characteristics may affect investor protection, orderly functioning of the market and financial stability.
9. When assessing the nature of a supervised entity, ESMA will consider the business and type of operations of the supervised entity, including its market role/mission, type, diversity and criticality of products and services offered by the supervised entity.
10. When assessing the scale of the business of a supervised entity, ESMA will have regard to relevant factors including headcount, revenue, number of clients and products, market share, interconnections with other industries/infrastructures, ancillary services and their relationship with core services and other factors specific to the size and market impact of the supervised entity.
11. When assessing the complexity of a supervised entity, ESMA will have regard to amongst other factors, its organisational structure and arrangements (group structure/relationships, shared services, outsourcing, etc.) as well as its operational characteristics in relation to people, processes, technology, product offerings and interconnections.

12. In calibrating its expectations, ESMA takes into account the conditions of a supervised entity's registration or recognition. A supervised entity's nature, scale and complexity may change after it is registered or recognised, and it is its responsibility to ensure that its internal controls stay commensurate with its nature, scale and complexity. ESMA will communicate through its supervision if it has a higher threshold of expectations under Section 5.1 and 5.2 than those established at registration or recognition.

5 Guidelines on internal controls

13. In order to demonstrate that supervised entities comply with Paragraph 2 of these Guidelines, supervised entities should demonstrate that their policies, procedures and working practices achieve the objectives of Sections **5.1** (Internal Control Framework) and **5.2** (Internal Control Functions) of these Guidelines.

5.1 Internal Control Framework

14. To ensure an effective IC framework, supervised entities should have the following components and characteristics in their policies, procedures and working practices.

General Principles

15. The Management Body of the supervised entity should be accountable for overseeing and approving all components of the IC Framework as well as overseeing that those components are subject to monitoring and are regularly updated by the Executive Senior Management. The supervised entity's Executive Senior Management should be responsible for establishing, implementing and updating the written internal control policies, procedures and practices that support the components of the IC framework.
16. As part of putting these policies and procedures in place, a supervised entity should have a clear, transparent and documented decision-making process and a clear allocation of roles and responsibilities within its IC Framework, including its business lines and IC functions.

Component 1.1 Control Environment

17. A supervised entity's Management Body and Executive Senior Management both contribute to establishing the tone at the top regarding the importance of internal control. The Executive Senior Management is responsible for the development and performance of internal control and assessing the adequacy and effectiveness of the control environment. The Management Body should exercise oversight of Executive Senior Management in these areas.

Characteristics

- 1.1.1** The supervised entity's Executive Senior Management should be responsible for establishing a strong culture of ethics and compliance within the supervised entity through the implementation of policies and procedures that govern the conduct of the supervised entity's staff.

- 1.1.2** The supervised entity's Executive Senior Management should be responsible for ensuring that the supervised entity's policies and procedures:
- i. Specify that the supervised entity's business should be conducted in compliance with the relevant Regulations and with the supervised entity's corporate values;
 - ii. Clarify that in addition to compliance with legal and regulatory requirements and internal policies, staff are expected to conduct themselves with honesty and integrity and perform their duties with due skill, care and diligence; and
 - iii. Ensure that staff are aware of the potential internal and external disciplinary actions, legal actions and sanctions that may follow misconduct.
- 1.1.3** The supervised entity's Executive Senior Management should establish, maintain and regularly update adequate written internal control policies, mechanisms and procedures.
- 1.1.4** The supervised entity's Executive Senior Management should retain responsibility for activities outsourced to external service providers or delegated to business partners.

Component 1.2 Risk Management

18. For the purposes of effective risk management, supervised entities should ensure that they have in place a dynamic and continuously evolving process for identifying, assessing and measuring all risks that could impact a supervised entity's ability to perform its obligations under the relevant Regulations, or its continued operation. For example, this includes risks resulting from the supervised entity's use of new technologies and changes to its external risk landscape. The process should enable the supervised entity to monitor, manage, mitigate and properly report material risks to these objectives.

Characteristics

- 1.2.1** The supervised entity should conduct its internal risk assessments in accordance with a defined and comprehensive risk assessment methodology.
- 1.2.2** The supervised entity should set its risk appetite and identify risk tolerance levels.
- 1.2.3** The supervised entity's risk assessment methodology should encompass all business lines and IC Functions of the supervised entity.

1.2.4 The supervised entity's risk assessment process should identify and assess changes that could significantly impact the system of internal control. This includes changes to its environment, organisation, activities and operations.

1.2.5 The supervised entity's risk assessment methodology should be subject to continuous evolution and improvement.

Component 1.3 Control Activities

19. The control activities should be preventative, detective, corrective or deterrent in nature.

Characteristics

1.3.1 *Segregation of Duties* – The supervised entity should ensure appropriate segregation of duties to manage risks of conflicts of interest, fraud and human error. The segregation of duties should ensure that staff members responsible for carrying out a task are not solely responsible for approving the outcome of its exercise. In particular, staff members responsible for the development, implementation or approval of a task/work item are not solely responsible for validating, assessing and reviewing it.⁸ Where this cannot be avoided, this should be mitigated by staff members not being exclusively responsible for the activity.⁹

1.3.2 *Documentation* – The supervised entity should document its policies and procedures covering all areas of their business activities subject to the provisions of the relevant Regulations.

1.3.3 *Documented Controls and Control Testing* – The supervised entity should document the key controls in place to ensure adherence to its policies and procedures established pursuant to the relevant Regulations.

1.3.4 *Designation of Responsibilities* – The supervised entity should designate in a clear and defined manner the roles or functions responsible for carrying out controls relating to the obligations under the relevant Regulations and specify their respective roles and responsibilities. In doing so, the supervised entity should distinguish between day-to-day controls at the business level and those carried out by specific control functions.

⁸ For example, staff members responsible for system development activities should not be involved in database administration, IT operations, and IT systems and network administration and maintenance. For CRAs, (i) persons conducting the analysis of a credit rating should not be solely responsible for the approval of the credit rating, (ii) persons responsible for the development of credit rating methodologies should not be solely responsible for their approval; (iii) persons responsible for the validation, assessment or review of a credit rating methodology should not be solely responsible for the approval of the validation, assessment or review.

⁹ For instance, through a four-eyes check.

- 1.3.5** *Authorisations and Approvals* – The supervised entity should have authorisation processes or mechanisms to ensure that only authorised individuals have access to information and tools on a need to know and least privilege basis. The supervised entity should also have processes or mechanisms in all business activities to ensure that activities are approved and executed only by staff members acting within the scope of their authority.¹⁰
- 1.3.6** *Verifications, validations, reconciliations and reviews* – The supervised entity should take measures to detect and act upon inappropriate, non-authorised, erroneous or fraudulent activities in a timely manner.¹¹
- 1.3.7** *Information and Communication Technology (ICT) General Controls* (only for supervised entities not subject to DORA) – The supervised entity should implement strategies, policies and procedures that ensure the digital operational resilience of the ICT systems of the supervised entity in supporting the supervised entity's business processes.

The supervised entity should design its ICT controls and solutions proportionately. Therefore, ICT controls will vary among organisations depending on the nature, scale and complexity of the underlying business processes and of the relevant functions supported by those systems.

Supervised entities should ensure that they have sufficient controls to ensure data quality, in terms of availability, confidentiality and integrity of data, including data validation, processing controls and data file control procedures.

The supervised entity should establish relevant information security management system and related control activities. As part of this, a supervised entity should determine the necessary controls to ensure the authenticity, confidentiality, integrity and availability of information as it is processed from source to ultimate user.

The supervised entity should establish and document all relevant ICT acquisition, development and maintenance processes control activities.

Component 1.4 Information and Communication

20. Supervised entities should establish procedures for the downward sharing of accurate, complete and good quality information to staff and external stakeholders. Supervised

¹⁰ For instance, for CRAs, only the persons designated as responsible for the respective tasks should carry out the credit rating process, the validation of methodologies and the review of the results of validation.

¹¹ This includes data validation and input controls, reviews of lists for authorised access to confidential information. For CRAs, such controls apply to, credit rating activities and to processes underlying these activities such as credit methodology/model validation.

entities should also establish procedures for the regular reporting of information about the internal control system and activities to the Management Body and Executive Senior Management including information relating to behaviour and adherence to internal controls.

Characteristics

- 1.4.1** The supervised entity should ensure appropriate internal and external communication, sharing accurate, complete and of good quality information in a timely manner to the market, clients, users of its products and services and regulators.
- 1.4.2** The supervised entity should establish upward communication channels, including a whistleblowing procedure, to enable the escalation of material internal control issues to the Management Body and Executive Senior Management. The Management Body and Executive Senior Management should also receive regular updates about the internal control system and activities, including on information security. The supervised entity should have escalation procedures in case of material disagreement between IC Functions and operating units.
- 1.4.3** The supervised entity should establish downward communication channels from the Management Body, Executive Senior Management and control functions to the staff. This should encompass regular updates on the objectives and responsibilities for internal control, communication of identified compliance or information security issues and presentations and training on policies and procedures.

Component 1.5 Monitoring Activities

- 21. Supervised entities should ensure that they undertake monitoring activities that will help ascertain whether the components of a supervised entity's internal control system are present and functioning effectively.

Characteristics

- 1.5.1** The supervised entity should ensure evaluations of the internal control system are carried out at different business levels of the supervised entity such as business lines, control functions and internal audit or independent assessment functions.
- 1.5.2** Monitoring activities should be designed and carried out in a way that enables the supervised entity to check whether the supervised entity meets its legal and regulatory requirements, including adhering to its internal codes of conduct,

policies and procedures. This includes the supervised entity's information security policies and procedures.

- 1.5.3** The evaluations of internal control systems should be carried out on a regular or thematic basis or through a mix of both.
- 1.5.4** The supervised entities should build ongoing evaluations into the business processes and adjust them to changing conditions.
- 1.5.5** The supervised entities should ensure that deficiencies identified from monitoring evaluations and the required remediation actions are reported to the Management Body and Executive Senior Management who should then monitor the timely implementation of corrective action(s).
- 1.5.6** In the case of outsourcing, the supervised entity should allocate the task for monitoring outsourced business processes to a member of staff. Supervised entities should ensure that sufficient information concerning objectives and delivery expectations is provided to the service provider, and that due diligence is conducted prior to the appointment of the provider.

5.2 Internal Control Functions

- 22. To ensure effective IC Functions, supervised entities should include the following components and characteristics in their policies, procedures and working practices.

General Principles

- 23. ESMA considers that supervised entities' IC functions should have sufficient resources and be staffed with individuals with sufficient expertise to discharge their duties. Staff working in IC Functions should have sufficient technical knowledge of the supervised entity's activities and the associated risks. Where a supervised entity has outsourced the operational tasks of an IC function to group level or to an external party, ESMA considers that the supervised entity retains full responsibility for the activities of the outsourced IC function. Supervised entities should ensure that staff in charge of IC functions should be of an appropriate seniority to have the necessary authority to fulfil their responsibilities. For example, staff members in charge of the Compliance, Risk Management, Internal Audit, Information Security Management, Review (for CRAs) and Oversight (for BMAs) Functions should have unfettered access and report to the Management Body on a regular basis.
- 24. Activities may be carried out at group level or by other legal entities within a corporate structure provided that the group structure does not impede the ability of a supervised entity's Management Body to provide oversight, and the ability of Executive Senior

Management to effectively manage its risks, or ESMA's ability to effectively supervise the supervised entity. In all cases Guideline 1.1.4 applies.

25. To ensure the independence of a supervised entity's IC functions, ESMA expects supervised entities to consider the following principles when establishing the roles and responsibilities of their IC Functions:
- i. IC functions should be organisationally separate from the functions/activities they are assigned to monitor, audit or control;
 - ii. IC functions should not perform any operational tasks that fall within the scope of the business activities they are intended to monitor, audit or control;
 - iii. The staff member in charge of an IC function should not report to a person who has responsibility for managing the activities the IC function monitors, audits or controls;
26. Staff performing responsibilities relating to IC functions should have access to relevant internal or external training to ensure the adequacy of their skills for the performance of the tasks.

Proportionality – Internal Control Functions

27. While all supervised entities are expected to demonstrate the characteristics of effective IC Functions outlined in these Guidelines, ESMA calibrates its expectations according to the nature, scale and complexity of a supervised entity, as described in Section 3.4 of these Guidelines.
28. This section sets out in more detail how ESMA takes into account proportionality in its supervision of IC Functions.

Segregation of duties

29. Segregation of duties should be built into the development of control activities. There may however be some instances where Union law does not require segregation of duties and such segregation is not practical considering the supervised entity's nature, scale and complexity. In this case, alternative controls may be more suitable. Where other controls are used, the supervised entities should document the rationale for the arrangement, identify the possible risks, implement compensating controls to address them and demonstrate that the arrangement does not impair the control environment.

Resources

30. For some supervised entities, it may not be proportionate to have full time staff in all functions given their nature, scale and complexity. In these instances, a supervised entity

may choose to scale the hours of resource to match control activities or outsource the activity.

Specialisation within Functions

31. As a supervised entity grows, and its control environment matures, it should use staff specialisation to benefit from staff expertise in key processes or risk areas. Supervised entities of a certain nature, scale and complexity should have in place dedicated monitoring or investigation teams within their Compliance Function.

Maturity of control activities

32. The maturity of control activities (i.e. manual, hybrid, automated, and in some instances, incorporating Artificial Intelligence tools) should reflect the nature, scale and complexity and overall risk profile of a supervised entity. For supervised entities of a certain nature, scale and complexity, there should be a higher degree of automated controls as well as a greater integration between the systems of control functions to optimise monitoring activities and a supervised entity's reporting of Management Information to Executive Senior Management and the Management Body.

Component 2.1 Compliance Function

33. The Compliance Function of a supervised entity is responsible for monitoring and reporting on compliance of the supervised entity and its employees with its obligations under the relevant Regulation. The Compliance Function is responsible for following changes in the laws and regulations applicable to its activities. The Compliance Function is also responsible for advising the Management Body on laws, rules, regulations and standards that the supervised entity needs to comply with and assess, in conjunction with other relevant functions, the possible impact of any changes in the legal or regulatory environment on the supervised entity's activities.

Characteristics

- 2.1.1** The Compliance Function should perform its functions independently of the business lines and should provide regular reports to the supervised entity's Management Body and, where relevant, directly to the INEDs.
- 2.1.2** The Compliance Function should advise and assist staff members to comply with the obligations under the relevant Regulation. The Compliance Function should be proactive in identifying risks and possible non-compliance through the timely monitoring and assessment of activities, as well as follow-up on remediation.

- 2.1.3** The Compliance Function should ensure that compliance monitoring is carried out through a structured and well-defined compliance-monitoring programme. The scope of Compliance activities should cover all the business and IT processes and systems that could affect the supervised entity's compliance with the relevant Regulation.
- 2.1.4** The Compliance Function, where appropriate in conjunction with other relevant functions, should assess the possible impact of any changes in the legal or regulatory environment on the supervised entity's activities and communicate, as appropriate, with the Risk Management Function on the supervised entity's compliance risk in a timely manner.
- 2.1.5** The Compliance Function should ensure that compliance policies are followed and should report to the Management Body and Executive Senior Management on the supervised entity's compliance risk.
- 2.1.6** The Compliance Function should cooperate with the Risk Management Function to exchange information necessary for their respective tasks.
- 2.1.7** The findings of the Compliance Function should be taken into account by the Management Body and Executive Senior Management as well as by the Risk Management Function within their risk-assessment processes.

Component 2.2 Risk Management Function

- 34. The Risk Management Function of a supervised entity is responsible for the development and implementation of the risk management framework.

Characteristics

- 2.2.1** The Risk Management Function should perform its functions independently of the business lines and units whose risks it oversees but should not be prevented from interacting with them.
- 2.2.2** The Risk Management Function should ensure that all risks that could impact a supervised entity's ability to perform its obligations under the relevant Regulations, or its continued operation, are identified, assessed and measured. Material risks to these objectives should then be monitored, managed, mitigated and properly reported by and to the relevant units within the supervised entity in a timely manner.
- 2.2.3** The Risk Management Function should monitor the risk profile of the supervised entity against the supervised entity's risk appetite to enable decision-making.

- 2.2.4** The Risk Management Function should provide advice on proposals and risk decisions made by business lines and inform the Management Body as to whether those decisions are consistent with the supervised entity's risk appetite and objectives.
- 2.2.5** The Risk Management Function should recommend improvements to the risk management framework and amendments to risk policies and procedures where necessary. The Risk Management Function should revisit risk thresholds in accordance with any changes in the organisation's risk appetite.

Component 2.3 Information Security Management Function (only for supervised entities not subject to DORA)

35. The information security management function of a supervised entity is responsible for the development and implementation of information security within the supervised entity. A supervised entity should establish a function that promotes an information security culture within the supervised entity.

Characteristics

- 2.3.1** The Information Security Management Function should be responsible for reviewing and monitoring the supervised entity's compliance with the supervised entity's information security policies and procedures.
- 2.3.2** The Information Security Management Function should manage the supervised entity's information security activities.
- 2.3.3** The Information Security Management Function should develop and deploy an information security awareness program for personnel to enhance the security culture and develop a broad understanding of the supervised entity's information security framework.
- 2.3.4** The Information Security Management Function should report to and advise the Management Body and Executive Senior Management on the status of the information security management system and risks (e.g., information about information security projects, information security incidents and the results of information security reviews).

Component 2.4 Internal Audit Function

36. An Internal Audit Function of a supervised entity is responsible for providing an independent, objective assurance and advisory activity designed to improve the organisation's operations. It helps the organisation to accomplish its objectives by bringing

a systematic, disciplined approach to evaluate and improve the effectiveness of the internal control system.

Characteristics

- 2.4.1** The Internal Audit Function should perform its functions independently of the business lines and other IC Functions. It should be governed by an internal audit charter that defines its role and responsibilities and is subject to oversight by the Management Body.
- 2.4.2** The Internal Audit Function should follow a risk-based approach and adhere to international internal audit standards.
- 2.4.3** The Internal Audit Function should independently review and provide objective assurance that the supervised entity's activities, including outsourced activities, comply with the supervised entity's policies and procedures as well as with applicable legal and regulatory requirements.
- 2.4.4** The Internal Audit Function should establish at least once a year, based on the annual internal audit control objectives, an audit plan which is subject to oversight by the Management Body.
- 2.4.5** The Internal Audit Function should provide regular reports to the independent members of the Management Body or to the Audit Committee, if in place.
- 2.4.6** The Internal Audit Function should communicate its audit recommendations in a clear and consistent way that allows the Management Body and Executive Senior Management to understand the materiality of recommendations and prioritise accordingly.
- 2.4.7** Internal audit recommendations should be subject to a formal follow-up procedure by the appropriate levels of management to report on and ensure their effective and timely implementation.

Component 2.5 Review Function (for CRAs only)

- 37. The Review Function of a CRA is responsible for reviewing credit rating methodologies on at least an annual basis. The CRA's Review Function is also responsible for the validation and review of new methodologies, and any changes to existing methodologies.

Characteristics

- 2.5.1** The Review Function should perform its functions independently of the business lines that are responsible for credit rating activities and should provide regular reports to the CRA's INEDs.

- 2.5.2** The CRA's shareholders or staff involved in business development should not perform the tasks of the Review Function.
- 2.5.3** Analytical staff should not participate in the approval of new, or validation and review of existing methodologies, models and key rating assumptions which they have developed.
- 2.5.4** Review function staff should either be solely responsible or have the majority of the voting rights in the committees that are responsible for approving methodologies, models and key rating assumptions.
- 2.5.5** The Review Function staff responsible for the validation and/or review of a methodology, and that are also involved in its development phase, should not be solely responsible or have the majority of voting rights in the methodology approval committees.
- 2.5.6** In case of outsourcing of the Review Function, the CRA should take into account Guideline 1.5.6. Additionally, the CRA should have suitable internal control mechanisms to ensure that it consistently adheres to regulatory requirements and maintains appropriate analytical quality standards.

Component 2.6 Oversight Function (for BMAs only)¹²

38. The Oversight Function oversees the main aspects of the provision of benchmarks. This includes, but is not limited to, the review of the benchmark's definition and methodology, the management of third parties involved in the provision of the benchmark, assessing internal and external audits or reviews of the administrator's control framework, and reporting to the relevant competent authorities any relevant misconduct.

Characteristics

- 2.6.1** The BMA Oversight Function maintains its independence from any Management Body or function of the BMA and any external party of the BMA. Independence assumes that members of the Oversight Function are not subject to conflicts of interest between their activities as members of the Oversight Function and their other activities. The BMA should implement an internal control operating framework to prevent and mitigate any potential conflict of interests.
- 2.6.2** The BMA should have clear policies and procedures regarding the set-up and responsibilities of the Oversight Function and its members, including policies

¹² Non-significant BMAs who apply article 26 of the BMR are expected to apply these Guidelines proportionally to the requirements of the article 26.

and procedures for benchmarks methodology updates and data integrity reviews.

- 2.6.3** The BMA Oversight Function should regularly perform a self-assessment to evaluate its effectiveness and the suitability of its members for the purpose of the function and to identify potential conflicts of interest and propose areas of improvement, if necessary.
- 2.6.4** The BMA Oversight Function should maintain a defined and regular communication channel with the Management Body, Executive Senior Management, and other key functions. The BMA Oversight Function should be also able to access and challenge Management Information and receive updates regarding the status of remedial actions following internal and external audits, risk, and compliance reports.
- 2.6.5** The BMA Oversight Function should maintain a defined communication channel with the relevant competent authorities, including reporting any misconduct or violation by administrators or contributors.